

DOCUMENTO DE AUDITORÍA: INFORME DE ANÁLISIS DE EXPOSITURA AUTOMATIZADA Y CONTROL REMOTO (REVERSE SHELL)

Fecha de Ejecución: 8 de Julio de 2026

Analista Responsable: Federico Fijtman (Técnico Superior en Programación / Analista GRC)

Herramienta Utilizada: Metasploit Framework MSFv6 (Motor Avanzado de Penetración)

Objetivo Auditado (Target): Servidor Linux Vulnerable - IP 192.168.56.101
(Metasploitable 2)

1. OBJETIVO DE LA AUDITORÍA TÉCNICA

El propósito de esta evaluación fue convalidar la efectividad del framework industrial Metasploit para la identificación, configuración y ejecución de vectores de explotación perimetrales. Se simuló el comportamiento de una amenaza avanzada para analizar cómo un fallo crítico de software permite evadir las políticas de seguridad de la red mediante cargas útiles (*payloads*) de conexión reversa.

2. PROCEDIMIENTO TÉCNICO Y RESOLUCIÓN DE CONFLICTOS (PASO A PASO)

🔍 **Paso 2.1: Indexación en la Base de Datos:** Se inicializó el motor PostgreSQL de Kali Linux y se ejecutó una búsqueda indexada bajo el parámetro de la vulnerabilidad global CVE-2011-2523, localizando el módulo excelente `vsftpd_234_backdoor`.

🔍 **Paso 2.2: Configuración de Variables Perimetrales:** Se parametrizó la variable remota (`RHOSTS`) apuntando al objetivo 192.168.56.101. Para la recepción de la consola, se configuró un payload reverso (`meterpreter_reverse_tcp`) enlazado a la interfaz local `eth0` de la máquina atacante (192.168.56.102).

🔍 **Paso 2.3: Gestión de Infraestructura y Sockets de Red:** Durante el primer intento de intrusión, el framework reportó un conflicto perimetral clásico (`Backdoor already in-use`), diagnosticando que el puerto oculto 6200 se encontraba saturado por procesos persistentes previos. Se aplicó un procedimiento de mitigación de infraestructura forzando un apagado de hardware completo en el hipervisor Oracle VirtualBox para purgar la caché de la BIOS virtual y liberar los sockets de red.

🔍 **Paso 2.4: Explotación y Acceso Definitivo:** Tras el reinicio prolijo del entorno, se relanzó el comando de ataque. El exploit burló las restricciones de red perimetrales abriendo con éxito una sesión interactiva avanzada en la memoria RAM del servidor.

```
kali@kali: ~/Desktop
Session Actions Edit View Help

Stdapi: System Commands

Command      Description
-----
execute      Execute a command
getenv       Get one or more environment variable values
getpid       Get the current process identifier
getuid       Get the user that the server is running as
kill         Terminate a process
localtime    Displays the target system local date and time
pgrep        Filter processes by name
pkill        Terminate processes by name
ps           List running processes
shell        Drop into a system command shell
suspend      Suspends or resumes a list of processes
sysinfo      Gets information about the remote system, such as OS

Stdapi: Webcam Commands

Command      Description
-----
webcam_chat  Start a video chat
webcam_list  List webcams
webcam_snap  Take a snapshot from the specified webcam
webcam_stream Play a video stream from the specified webcam

Stdapi: Mic Commands

Command      Description
-----
listen       listen to a saved audio recording via audio player
mic_list     list all microphone interfaces
mic_start    start capturing an audio stream from the target mic
mic_stop     stop capturing audio

Stdapi: Audio Output Commands

Command      Description
-----
play         play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

meterpreter > |
```

3. CONCLUSIÓN Y ANÁLISIS DE IMPACTO PARA GRC

La obtención del prompt interactivo "meterpreter >" representa el nivel máximo de compromiso sobre un activo de la organización. Este tipo de payloads permite al atacante operar directamente cargado en la memoria RAM, evadiendo los sistemas de detección tradicionales y permitiendo la ejecución de comandos con privilegios máximos de administrador (root).

La recomendación obligatoria de Gobierno y Riesgo es el aislamiento total del servidor hasta aplicar una versión del servicio de transferencia de archivos libre de código malicioso.